SECCIÓN 6.5

Coordinación con otros equipos y evaluación de impacto

Temas de esta sección:

- El SOC como punto de coordinación, no como equipo que responde solo
- Cuándo involucrar a IR, IT, identidad, redes, cloud, apps y negocio
- Impacto técnico vs impacto de negocio: la misma alerta, distintas consecuencias
- Evaluar criticidad del activo y de la cuenta
- Cómo pedir ayuda de forma concreta y accionable
- Handoff operativo y registro de decisiones coordinadas

El SOC no responde incidentes solo. Detecta, valida, correlaciona y coordina. Es el punto central que activa a los equipos con acceso y autoridad para actuar.

Lo que el SOC APORTA a la coordinación

- Evidencia técnica y línea temporal
- Hipótesis documentada con nivel de certeza
- Identificación del activo y usuario involucrado
- Evaluación inicial de impacto y alcance
- Contexto para que otros equipos actúen sin empezar de cero
- Registro de decisiones tomadas y pendientes
- Actualización de estado durante el incidente

Lo que el SOC NO hace solo

Aislar servidores productivos sin IT o IR
Bloquear IP globalmente sin validar impacto
Deshabilitar cuentas ejecutivas sin IAM
Comunicar públicamente un incidente
Declarar compromiso sin evidencia suficiente
Ejecutar playbooks de contención avanzada
Tomar decisiones de negocio sobre continuidad

La coordinación no es demorar la respuesta. Es activar a las personas correctas con la información correcta en el momento correcto.

No todos participan en todos los casos. El SOC debe identificar quién tiene el conocimiento, el acceso o la autoridad necesaria:

INCIDENT RESPONSE

Ejecución permitida con persistencia · Movimiento lateral · Web shell · Ransomware posible · Análisis forense · Contención sensible

IT / INFRAESTRUCTURA

Servidor productivo afectado · Aislamiento de host crítico · Validación de inventario · Ventana de mantenimiento · Reiniciar servicio

IDENTIDAD / IAM

Impossible travel · MFA fatigue · Nuevo método MFA · OAuth app sospechosa · Cuenta privilegiada · Revocar sesiones/tokens

REDES

C2 sospechoso · Movimiento lateral · Bloqueo de IP/dominio · Tráfico entre segmentos · Firewall/proxy logs

APLICACIONES

WAF alert relevante · Command Injection · SQL Injection con impacto · Web shell · Abuso de API · Logs internos de app

NEGOCIO / DUEÑO DEL SISTEMA

Servidor de pagos/facturación · Portal de clientes · Aplicación logística · Cuenta ejecutiva · Impacto potencial en clientes

Una respuesta madura considera ambos. El mismo evento técnico puede tener consecuencias muy distintas según el activo.

IMPACTO TÉCNICO	IMPACTO DE NEGOCIO
Malware ejecutado	Caída del portal de pagos
Cuenta comprometida	Interrupción de atención al cliente
Web shell creado	Pérdida de acceso a facturación
Servidor con proceso sospechoso	Exposición de información legal
Shadow copies eliminadas	Demora en operación logística
Datos descargados	Posible incumplimiento regulatorio

Ejemplo: w3wp.exe→cmd.exe→whoami en TEST-WEB-01 (ambiente de pruebas) vs en WEB-PAY-01 (portal de pagos). Técnicamente igual. Impacto de negocio completamente distinto.

6.5 | Evaluar criticidad del activo y de la cuenta

El mismo tipo de alerta tiene prioridades completamente distintas según quién y qué está involucrado:

Criticidad del ACTIVO

Alta criticidad — priorizar:
- Controlador de dominio (DC)
- Servidor de pagos o facturación
- Portal de clientes o e-commerce
- Servidor de identidad (AD, IdP, LDAP)
- Infraestructura de backup
- Sistemas regulados (PCI, HIPAA)

Baja criticidad — analizar sin urgencia extrema:
- Equipos de usuario sin datos sensibles
- Ambientes de desarrollo aislados
- Sistemas de prueba sin conexión a prod

Criticidad de la CUENTA

Alta criticidad — priorizar:
- Domain Admin o Enterprise Admin
- Cuentas ejecutivas (CEO, CFO, CISO)
- Cuentas de servicio con privilegios
- Operadores de infraestructura crítica
- Usuarios con acceso a datos sensibles

Baja criticidad — analizar sin urgencia extrema:
- Cuentas de usuario sin privilegios
- Cuentas de demo o temporales
- Servicios de bajo impacto

La misma alerta de PowerShell en IT-LAP-044 (usuario IT con ticket) vs en DC-01 (controlador de dominio sin ticket) requiere respuestas completamente distintas.

6.5 | Cómo pedir ayuda y documentar decisiones coordinadas

Coordinar bien no significa demorar. Significa activar a las personas correctas con la información correcta:

Pedido de ayuda ambiguo

```
"Necesitamos revisar algo raro en un servidor."
```

Pedido útil y accionable

```
Se observa posible Command Injection en WEB-PAY-01
(portal de pagos). WAF detectó payload con Response 200.
EDR muestra w3wp.exe→cmd.exe→whoami. Necesitamos
validar impacto de aislar o aplicar bloqueo específico.
¿Quién puede confirmar criticidad?
```

Registro de decisiones coordinadas

```
10:15 - SOC identifica posible web shell en WEB-PAY-01
10:20 - Se escala a IR, infraestructura y aplicaciones
10:28 - Aplicaciones confirma que /uploads no debería
        aceptar ejecución
10:35 - Negocio informa que el portal procesa pagos
activos
10:42 - IR recomienda preservar shell.aspx y aplicar
        regla WAF específica
10:50 - Redes aplica bloqueo a IP origen
11:05 - Infra prepara ventana para contención coordinada
```

Un buen pedido de ayuda permite decidir. Un registro de decisiones permite reconstruir por qué se actuó de una forma y no de otra.

Handoff: siempre incluir resumen, timeline, acciones realizadas, acciones pendientes, limitaciones y próximos pasos.